

Politique de Gouvernance des données

Ce document définit le cadre de gouvernance des données de Spotify, établissant les principes, politiques et processus garantissant la qualité, la sécurité, la conformité réglementaire et l'utilisation optimale des données à l'échelle mondiale.

1. Principes fondamentaux de gouvernance

Principe	Engagement	Mise en oeuvre
Principe de responsabilité	Chaque dataset possède un responsable désigné (Data Steward) qui garantir la conformité et la qualité	Attribution des rôles (matrice RACI) Revue des responsabilités Comité de gouvernance des données
Principe de transparence	Communication claire aux utilisateurs sur l'utilisation de la donnée	Documentation interne complète des flux de données Politique de confidentialité accessible
Principe de sécurité	Protection maximale des données sensibles	Contrôle d'accès basé sur les rôles Authentification multi-facteurs obligatoire
Principe de qualité des données	Garantir l'exactitude, la complétude et la fiabilité des données	Scores de qualité mesurés sur 5 dimensions : exactitude, complétude, cohérence, actualité, validité
Principe de conformité réglementaire	Respect absolu du RGPD, CCPA et autres réglementations applicables	Délégué à la Protection des Données (DPO) dédié Programme de formation continue sur la conformité
Principe de minimisation des données	Collecter uniquement les données nécessaires aux finalités définies	Suppression automatique des données après expiration des délais de rétention Validation obligatoire pour toute nouvelle collecte de données
Principe des droits utilisateurs	Faciliter l'exercice des droits RGPD et CCPA	Portail utilisateur pour accès, rectification et suppression
Principe d'amélioration continue	Évolution constante du cadre de gouvernance	Veille réglementaire active Revue semestrielle du cadre de gouvernance
Principe d'éthique des données	Utilisation éthique des données, notamment dans l'IA.	Transparence sur les décisions automatisées Tests de biais sur les modèles de recommandation

2. Cadre de conformité (GDPR / CCPA / PDPA / autres)

Spotify adopte une approche privacy-by-design et privacy-by-default pour toutes les fonctionnalités et traitements.

- Consentement et base légale
 - Consentement explicite lorsque requis (profilage, publicité ciblée, données sensibles)
 - Documentation obligatoire des bases légales.
- Droits des utilisateurs. Spotify garantit :
 - droit d'accès,
 - rectification,
 - suppression (droit à l'oubli),
 - portabilité,
 - limitation du traitement,
 - droit d'opposition.

→ Les demandes doivent être traitées dans les délais légaux (30 jours RGPD).

- Gestion des violations de données
 - Procédures documentées de détection, notification et remédiation.
 - Notification aux autorités dans les 72h (GDPR)
- Transferts internationaux
 - Conformité aux mécanismes de transfert :
SCC, Privacy Shield alternatives, exigences locales.

3. GESTION DE LA QUALITÉ DES DONNÉES

Spotify garantit la qualité de ses données au travers des dimensions d'exactitude, de complétude, de cohérence, d'actualité de validité et d'unicité.

- Processus de qualité
 - **Profilage des données**
 - **Nettoyage des données**
 - **Surveillance continue**

4. Classification des données

Niveau	Type de données	Exemples	Mesures de protection
Public	Données non sensibles	Catalogue musical	Chiffrement standard
Interne	Données opérationnelles	Métriques agrégées	Accès contrôlé
Confidentiel	Données personnelles	Préférences utilisateur	Chiffrement + RBAC + MFA
Hautement confidentiel	Données sensibles	Données paiement, santé	Chiffrement renforcé + Tokenisation + Audit logs

6. Cycle de vie des données (POSMAD)

1. **PLAN** : Définition des besoins et conception des datasets
2. **OBTAIN** : Collecte via APIs, événements utilisateur, partenaires
3. **STORE & SHARE** : Stockage sécurisé dans data lakes/warehouses
4. **MAINTAIN** : Nettoyage, enrichissement, archivage
5. **APPLY** : Utilisation pour analytics, ML, personnalisation
6. **DISPOSE** : Suppression sécurisée après fin de rétention

Spotify met en place un catalogue central des données regroupant :

- Glossaire métier, définitions standard, documentation des pipelines, propriétaires des données, règles de qualité, niveaux de sensibilité.

Des standards d'architecture sont définis pour :

- les modèles de données, les identifiants uniques, les schémas d'API et d'intégration, les pipelines ML et streaming.

7. RÉVISION ET MISE À JOUR

Calendrier de révision

- **Revue complète du guide de gouvernance** : Annuelle
- **Mises à jour ponctuelles** : En fonction des évolutions réglementaires
- **Validation** : Par le Comité de Gouvernance des Données

Gestion des versions

- Toutes les versions sont archivées avec horodatage
- Communication obligatoire des changements majeurs à tous les collaborateurs
- Période de transition de 30 jours pour adaptation aux nouvelles exigences